

SIMATS ENGINEERING
ASSESSMENT TOOL 3

COURSE CODE:CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 5 TOTAL MARKS: 25

Annexure A

Comparative Analysis

Code of Conduct:

I Atchaya Chandran R(192521394) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A

Comparative Analysis

1. Apply SSL/TLS and IPsec protocols to a secure communication scenario and determine which provides better security for web-based and network-layer protection.
2. Design a secure email system by comparing end-to-end encryption and gateway-based encryption, and justify the most suitable approach for enterprise use.
3. Apply HMAC and Digital Signature techniques to a data transmission scenario and analyze which method provides better authentication and integrity.
4. Create a spam detection system by comparing supervised learning and unsupervised learning approaches, and evaluate their effectiveness in real-world email filtering.
5. Design a secure communication framework by comparing AES and RSA encryption techniques, and determine their roles in achieving confidentiality and efficiency.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Scope of Items	20%	Selects highly relevant items with clear scope and justification	Selects appropriate items with minor gaps	Selection is limited or partially relevant	Items are unclear or not relevant
Comparison Depth	25%	Provides detailed and comprehensive comparison across multiple aspects	Provides adequate comparison with some depth	Limited comparison with few aspects	Very minimal or no comparison
Use of Evidence	20%	Supports comparison with accurate data, examples, or references	Uses some supporting evidence with minor gaps	Limited or weak supporting evidence	No supporting evidence provided
Critical Thinking	20%	Demonstrates strong critical thinking with clear interpretation and reasoning	Shows reasonable interpretation with minor gaps	Basic interpretation; lacks depth	No meaningful interpretation
Clarity of Presentation	15%	Well-organized, clear, and logically structured presentation	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

Question 1: Web-Based vs. Network-Layer Protection (SSL/TLS vs. IPsec)

1. Scope & Application Scenario

Consider an enterprise scenario where remote employees access corporate resources (web portals and internal server traffic) over the untrusted Internet.

- SSL/TLS (Transport Layer): Secures application-specific client-server sessions (e.g., HTTPS).
- IPsec (Network Layer): Secures all IP traffic between two endpoints regardless of the application (e.g., VPNs).

2. Comparative Analysis

Feature / Criteria	SSL/TLS (Transport Layer Security)	IPsec (Internet Protocol Security)
OSI Layer	Application / Transport Layer (Layer 4/7) [source: 1]	Network Layer (Layer 3) [source: 1]
Transparency	Application-aware; integrated into browsers/apps. [source: 1]	Transparent to applications; operates at packet level. [source: 1]
Deployment Complexity	Low; no client software installation needed for HTTPS. [source: 1]	High; requires specialized client software/OS configuration for end-to-end setups. [source: 1]
Granularity	Fine-grained (per-session / per-application basis). [source: 1]	Coarse-grained (host-to-host, host-to-network, or network-to-network). [source: 1]
Modes of Operation	Handshake, Record, Alert, and Change Cipher Spec Protocols. [source: 1]	Transport Mode (payload only) & Tunnel Mode (entire IP packet). [source: 1]

3. Evidence & Critical Evaluation

- **Web-Based Protection:** SSL/TLS is superior. Because TLS operates above TCP, it provides seamless, end-to-end security directly between web browsers and servers without requiring network modifications or admin privileges on the client device.
- **Network-Layer Protection:** IPsec is superior. IPsec Tunnel Mode encrypts the entire original IP packet (header + payload) inside a new IP header, ensuring that all sub-protocols (UDP, TCP, ICMP) are completely shielded from eavesdropping.

Conclusion: SSL/TLS provides better, lightweight security for web-based access (HTTPS), whereas IPsec is necessary for network-layer protection (site-to-site or remote-access VPNs).

Question 2: Enterprise Secure Email System (End-to-End Encryption vs. Gateway-Based Encryption)

1. Scope & Design Scenario

An enterprise needs to secure sensitive internal and outbound email communications against unauthorized access, wiretapping, and data leakage.

2. Comparative Analysis

Feature / Criteria	End-to-End Encryption (E2EE - e.g., PGP, S/MIME)	Gateway-Based Email Encryption
Encryption Endpoint	Sender's endpoint device to Receiver's endpoint device. [source: 1]	Sender's Email Gateway to Receiver's Email Gateway (or recipient portal). [source: 1]
Key Management	User-managed or PKI-managed at individual device level. [source: 1]	Centrally managed by network/email administrators. [source: 1]
DLP & Content Inspection	Failed/Blocked: Gateways cannot inspect encrypted message content. [source: 1]	Supported: Central gateways inspect, scan, and enforce policies before encrypting. [source: 1]
User Overhead	High; users must manage keys/certificates and sign/encrypt manually. [source: 1]	Low; fully transparent to end-users (automatic policy enforcement). [source: 1]

3. Evidence & Critical Justification for Enterprise Use

- While E2EE (PGP/S/MIME) offers complete trust (neither the server nor host network can view message contents), it creates major compliance, Data Loss Prevention (DLP), and malware scanning barriers for enterprises.
- Gateway-Based Encryption is the most suitable approach for standard enterprise deployment because:
 1. It allows automated centralized inspection for regulatory compliance (e.g., HIPAA, GDPR) and threat detection.
 2. It enforces encryption policies transparently based on content (e.g., detecting credit card numbers) without relying on user compliance.

Design Choice: Implement a Hybrid Gateway Model—Gateway-Based Encryption for standard corporate operations, supplemented by S/MIME for executive-level, strict E2EE communication.

Question 3: Data Transmission Authentication & Integrity (HMAC vs. Digital Signatures)

1. Scope & Scenario

High-throughput data stream needing integrity verification and sender authentication across a network.

2. Comparative Analysis

Feature / Criteria	Hash-Based Message Authentication Code (HMAC)	Digital Signature (RSA / ECDSA)
Cryptography Type	Symmetric Key Cryptography [source: 1]	Asymmetric Key Cryptography [source: 1]
Computational Overhead	Very Low (fast hash iterations like SHA-256). [source: 1]	High (modular exponentiations / elliptic curve math). [source: 1]
Non-Repudiation	No: Shared key means either party could have created the HMAC. [source: 1]	Yes: Only the private key holder can generate the signature. [source: 1]
Verification Method	Both parties share the identical secret key . [source: 1]	Sender signs with Private Key ; Receiver verifies with Public Key . [source: 1]

3. Evidence & Critical Analysis

- Mathematical Operations:
 -
 -
- Performance: HMAC is orders of magnitude faster than Digital Signatures, making it ideal for real-time packet processing (e.g., IPsec AH/ESP).
- Security & Non-Repudiation: Digital signatures provide true non-repudiation because public-key ownership uniquely identifies the signer. HMAC only proves that someone holding the shared secret generated the tag.

Evaluation: For Integrity and High-Speed Authentication, HMAC provides superior efficiency. For Legal Integrity and Non-Repudiation, Digital Signatures are strictly required.

Question 4: Spam Detection Systems (Supervised vs. Unsupervised Learning)

1. Scope & Application

Filtering incoming email streams in real-time to classify messages as *Spam* or *Ham* (legitimate).

2. Comparative Analysis

Feature / Criteria	Supervised Learning (e.g., Naive Bayes, SVM)	Unsupervised Learning (e.g., K-Means, DBSCAN)
Data Requirement	Labeled dataset (Emails explicitly tagged as Spam/Ham). [source: 1]	Unlabeled dataset (Raw email streams). [source: 1]
Classification Goal	Predict discrete pre-defined class labels. [source: 1]	Discover hidden patterns, clusters, and anomalies. [source: 1]
Adaptability to Zero-Day Attacks	Poor; struggles with unseen spam techniques without retraining. [source: 1]	High; flags novel spam patterns as statistical anomalies. [source: 1]
Accuracy	Extremely High for known spam signatures. [source: 1]	Moderate; high risk of False Positives (legitimate emails misclassified). [source: 1]

3. Evidence & Real-World Effectiveness

- Supervised Learning (Naive Bayes/SVM): Achieves high accuracy () on static distributions using features like term frequency-inverse document frequency (TF-IDF). However, it requires continuous human labeling to keep up with adversary tactics.
- Unsupervised Learning (Clustering/Anomaly Detection): Detects novel spam campaigns (e.g., bursty mass-mailing from new botnets) without needing prior labels, but suffers from higher false-positive rates.

Evaluation: Supervised learning is vastly superior for day-to-day precision filtering. However, modern enterprise filtering engines utilize Ensemble/Hybrid approaches: Supervised models handle standard filtering, while Unsupervised models detect zero-day phishing campaigns.

Question 5: Hybrid Cryptographic Framework (AES vs. RSA)

1. Scope & Design Framework

Designing a scalable, secure end-to-end communication system that provides both confidentiality and high performance.

2. Comparative Analysis

Feature / Criteria	AES (Advanced Encryption Standard)	RSA (Rivest-Shamir-Adleman)
Algorithm Class	Symmetric Key Encryption [source: 1]	Asymmetric Key Encryption [source: 1]
Key Size & Security	128, 192, or 256 bits (high security density). [source: 1]	2048, 3072, or 4096 bits. [source: 1]
Processing Speed	Extremely fast (hardware-accelerated via AES-NI). [source: 1]	Slow (computationally expensive modular exponentiation). [source: 1]
Key Distribution	Difficult (requires secure key exchange channel). [source: 1]	Easy (public keys distributed freely). [source: 1]

3. Critical System Architecture Design (Hybrid Cryptosystem)

To maximize both confidentiality and efficiency, neither algorithm should be used in isolation. Instead, a Hybrid Cryptographic Architecture (similar to TLS/PGP) is designed as follows:

[Sender]

[Receiver]

|

|

|-- 1. Generate Random Symmetric Key (K_sess) -----|

|-- 2. Encrypt Data: C = AES-GCM(Data, K_sess) ----->|

|-- 3. Encrypt Session Key: Enc_K = RSA_Encrypt(K_sess, PU_B) ->|

|

|-- 4. Decrypt Key: K_sess = RSA_Decrypt(Enc_K, PR_B)

|

|-- 5. Decrypt Data: Data = AES-GCM(C, K_sess)

1. Role of RSA (Key Exchange & Authentication): RSA securely transmits a small, randomly generated symmetric session key (K_sess) using the receiver's public key (PU_B).

2. Role of AES (Data Confidentiality): AES encrypts the actual payload using K_sess (e.g., AES-256-GCM), providing bulk encryption speed and authenticated encryption.

Conclusion: RSA solves the key distribution problem with low overhead because it only processes small key sizes. AES provides efficient, high-speed confidentiality for large payloads. Together, they form the foundation of modern network security protocols.